

Incident Response Engagement Findings Report

INC-2026-007 - IDOR & Broken Access Control

CLIENT

NexaCorp

Employee data exposure investigation

Engagement reference INC-2026-007

Assessment lab (IDOR + Broken Access Control)

Prepared by

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 23 June 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
DISCLAIMER	3
EXECUTIVE SUMMARY	4
A. Introduction	4
B. Scope	4
C. Engagement summary	5
D. Overview of findings	7
E. Overview of recommendations	8
METHODOLOGY	9
A. Procedure	9
B. Severity Ratings	10
INVESTIGATION TECHNICAL SUMMARY	11
I1. Unauthorized valid account	11
I2. IDOR on the employee directory	13
I3. Broken access control and bulk exfiltration	15
I4. Debug token disclosed in admin page	17
RISK MATRIX	18
MITRE ATT&CK MAPPING	19
TOOLS AND STANDARDS	20
GLOSSARY AND ACRONYMS	22

Confidentiality Statement

This report documents Mission 07 of the BeCode Corp internal cybersecurity training programme, an incident response engagement conducted against a controlled laboratory environment simulating an internal web application incident at the fictitious organisation NexaCorp. No real production system, customer data, or third-party infrastructure was targeted, accessed, or affected. All identities, hostnames and accounts referenced belong to the BeCode training environment and have no production analogue.

This document is classified as Internal - Not for distribution under reference BCC-2026 | INC-2026-007. Subject to that, the analyst retains the right to share this report as part of professional portfolios, certification evidence, and job applications, in line with the BeCode Corp policy on training deliverables.

Disclaimer

The findings and recommendations are based on the evidence package provided for INC-2026-007 (NexaPortal Apache access log, the portal authentication log, a network capture, the Wazuh alert export, the administrative export CSV, and the IT-provisioned account register) covering the incident of 19 June 2026. This is an assessment engagement : the deliverable is investigation and reporting; no detection rules were authored. The methodology follows NIST SP 800-61r2 and the SANS PICERL process.

Executive Summary

A. Introduction

On 19 June 2026, NexaCorp detected an automated walk through its internal portal (NexaPortal) employee directory, followed by access to a restricted administrative section and a bulk data download. The BeCode SOC team was tasked with establishing which account was used and whether it is legitimate, how many employee records were accessed, whether data was exfiltrated from the administrative section, and whether the incident connects to the prior incidents of the month (INC-2026-004 to 006). This is an assessment engagement; there is no detection-rule (Phase 2) deliverable.

B. Scope

Target : NexaPortal, a PHP application on Apache 2.4.57 (Debian), host 192.168.10.26, Wazuh agent lab07-nexaportal. Window : 19 June 2026. Evidence : Apache access log, portal authentication log, network capture, Wazuh alert export, administrative export CSV, IT-provisioned account register. In scope : log analysis, network capture analysis, SIEM alert review, impact and data-protection assessment. Out of scope : live forensic acquisition, malware reverse engineering, detection-rule engineering.

C. Engagement summary

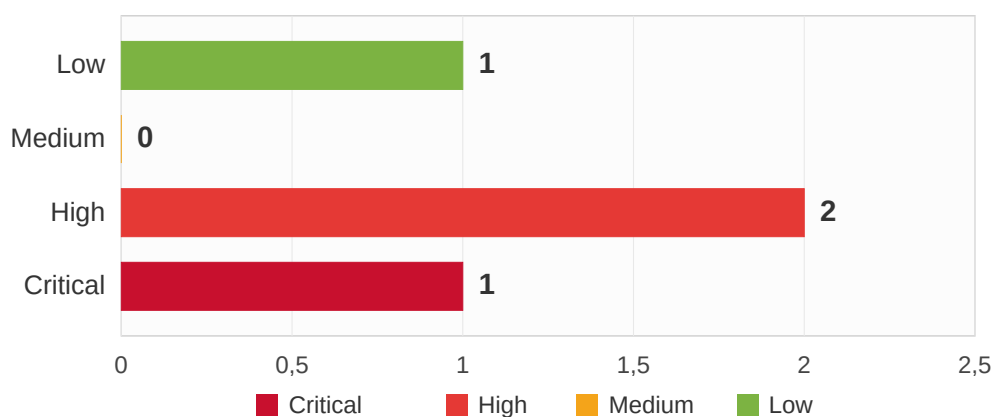
An attacker authenticated to NexaPortal at 16:23:01 UTC using the account m.renard, which does not appear in NexaCorp's IT-provisioned account register. The account is the same unauthorized foothold first seen in INC-2026-006 and traced to the compromise of INC-2026-005, and it was never removed. From a single source (172.16.50.10, the same address used in INC-2026-004 and INC-2026-005), the session enumerated the employee directory through an Insecure Direct Object Reference, reading 47 distinct records in just over two minutes, then reached an administrative page that returned HTTP 200 instead of the 302 redirect served to unauthorized requests, and downloaded a full employee export.

The exported data covers 47 employees and includes name, corporate email, department, job title, phone number and salary band : personal data under the GDPR. The exposure is not uniform : it includes senior executives in the top salary band and the organization's own Data Protection Officer, and it includes the account of the employee whose credentials were stolen by SQL injection in INC-2026-004, closing the loop on the month's campaign.

The SIEM produced 211 alerts during the window and not one concerns this attack : every alert was raised against unrelated scanner noise, while the attacker, whose every request returned HTTP 200 under a normal browser user agent on an authenticated session, generated zero alerts. A signature-based ruleset keyed on 4xx errors and known-scanner user agents is structurally blind to authorization abuse.

The overall posture is rated **CRITICAL** : a confirmed exfiltration of personal data, enabled by a foothold left in place after a prior incident and invisible to existing monitoring. The single most important point is that the root cause is not the IDOR flaw in isolation, it is the failure to remove the attacker's account after INC-2026-005. The XSS mitigations deployed on 18 June (HttpOnly, Content Security Policy) were correct and effective but irrelevant, because the attacker no longer needed XSS : a valid login was enough.

Findings by Severity Level

**B.**

One finding reaches Critical severity: the broken access control on the administrative area that enabled the confirmed bulk exfiltration of 47 employees' personal data (I3). The assessment also identified **two High-severity findings** (I1, the unauthorized account m. renard left in place since INC-2026-005, and I2, the IDOR that allowed sequential enumeration of the entire employee directory) and **one Low-severity finding** (I4, the debug token disclosed in the admin page source).

In conclusion, the volume and severity of findings, combined with a confirmed personal-data breach that existing monitoring did not detect, render the affected portal unsuitable for continued operation without remediation. Acting on the recommendations in this report would remove the attacker's foothold, close the authorization flaws on the employee directory and the admin area, and move NexaCorp's detection practice toward behavioural coverage of authorization abuse.

D. Overview of findings

Ref	Description	Severity
I1	Unauthorized valid account, un-removed foothold (m.renard)	HIGH
I2	Insecure Direct Object Reference on the employee directory (47 records)	HIGH
I3	Broken access control on admin area and bulk PII exfiltration	CRITICAL
I4	Sensitive debug token disclosed in admin page source	LOW

E. Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
I1	Un-removed foothold	<i>Disable and delete m.renard now; audit the user table for any account absent from the IT register. Root cause, takes priority.</i>
I2	IDOR on directory	<i>Enforce object-level authorization on employees.php; rate-limit and alert on directory enumeration; prefer non-guessable ids.</i>
I3	Broken access + exfil	<i>Enforce function-level role authorization server-side on every admin page and export; treat as GDPR-reportable (Art 33/34).</i>
I4	Debug token disclosure	<i>Remove debug tokens and developer comments from client-facing responses; strip comments at build time.</i>

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 (Computer Security Incident Handling Guide) and the SANS PICERL process. This is an assessment engagement : there is no detection-engineering phase.

01. Scope and evidence triage

- Validate the evidence bundle (access log, auth log, pcap, Wazuh export, export CSV, account register)
- Confirm engagement boundaries



02. Account and source identification

- Reconcile the authentication log against the IT account register
- Identify the attacker account and pin the source address



03. Activity reconstruction

- Map the IDOR enumeration and the admin access from the access log
- Quantify records accessed; separate attack from legitimate, scanner and failed activity



04. Impact and exfiltration proof

- Corroborate the export with the network capture and the CSV
- Characterise exposed personal data and assess the GDPR position



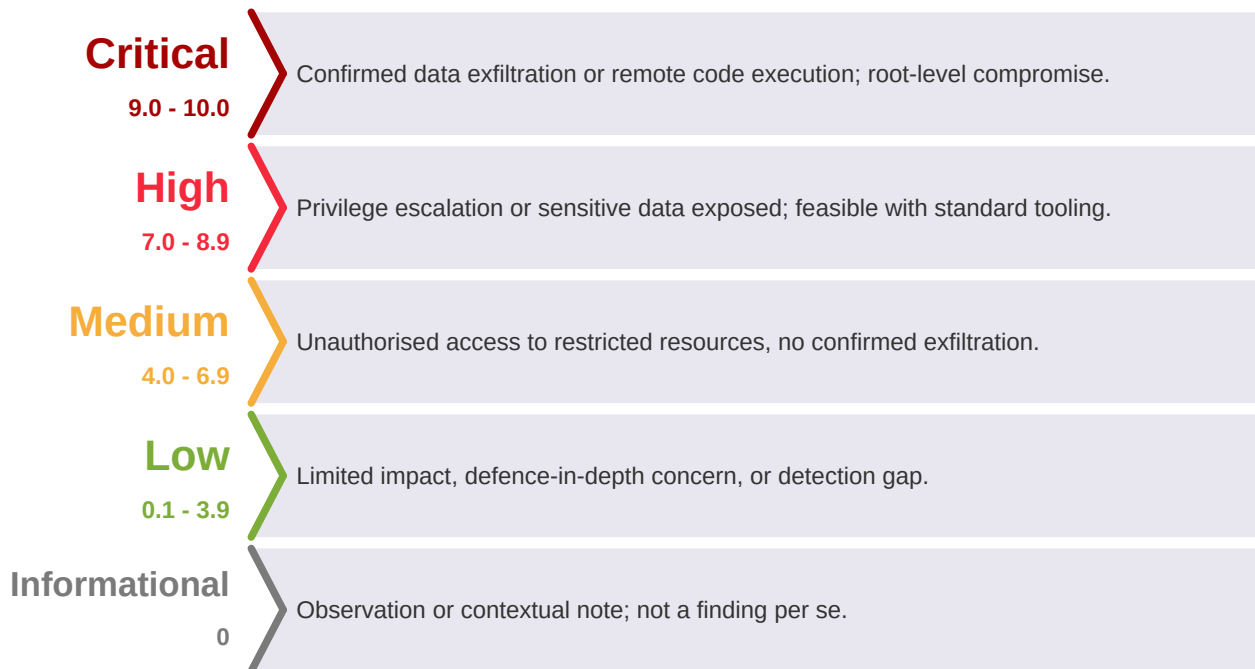
05. Detection-gap analysis and reporting

- Review the Wazuh alerts (caught vs missed, and why)
- Consolidate findings, MITRE mapping and remediation



B. Severity Ratings

Severity uses the CVSS v3.1 base score as foundation, with engagement-contextual elevation where a confirmed personal-data breach materially exceeds the CVSS base (noted per finding).



Investigation Technical Summary

This section documents the four findings identified during the investigation. Each finding includes the affected scope, a CVSS-derived severity assessment, the technical description, evidence, and a remediation recommendation.

11. Unauthorized valid account, un-removed foothold

Severity:

HIGH

Finding type:

Unauthorized access (valid account / persistence)

CVSS v3.1 base score:

7.5 (High) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CWE:

CWE-284 (Improper Access Control)

MITRE ATT&CK:

T1078 (Valid Accounts)

Affected scope:

- NexaPortal authentication (host 192.168.10.26), account m.renard

Description:

The portal authentication log records a successful login for m.renard at 16:23:01 UTC from 172.16.50.10. Cross-checked against NexaCorp's IT-provisioned account register, m.renard does not exist; a legitimate employee with the same surname does (p.renard, Pierre Renard), consistent with an account named to blend in. This is the same unauthorized account observed in INC-2026-006 and traces to the foothold established in INC-2026-005. It was not removed during the remediation of those incidents, so the attacker retained a valid login.

The credential brute force seen earlier in the log (10:11-10:12 UTC from 172.16.50.40, all failures) is unrelated scanner noise that never succeeded. The actual compromise is a single valid login from 172.16.50.10, the same source address used in INC-2026-004 and INC-2026-005.

Proof of evidence:

```
# Authentication log : success for an account absent from the register
19/Jun/2026:16:23:01 +0000 [AUTH] result=SUCCESS user=m.renard src=172.16.50.10
uri=/portal/login.php
# Account register (employee_roster.txt) : no m.renard, only p.renard
p.renard | Pierre Renard | user
```

Recommendation:

- **P0 - Disable and delete m.renard immediately.** Audit the NexaPortal user table for any other account absent from the IT register. This is the root cause; every other fix is secondary until it is done.
- Reconcile the application user store against the IT account register on a schedule, and alert on any account that does not match.
- Review the remediation of INC-2026-005 and 006 : the foothold should have been removed then.

References and articles:

<https://attack.mitre.org/techniques/T1078/>

<https://cwe.mitre.org/data/definitions/284.html>

I2. Insecure Direct Object Reference on the employee directory

Severity:

HIGH

Finding type:

Authorization flaw (object level)

CVSS v3.1 base score:

7.7 (High) - AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

CWE:

CWE-639 (Authorization Bypass Through User-Controlled Key)

MITRE ATT&CK:

T1119 (Automated Collection), T1213 (Data from Information Repositories)

Affected scope:

- /portal/employees.php parameter id (host 192.168.10.26)

Description:

The endpoint /portal/employees.php selects the employee record to display from a client-supplied integer parameter, id, with no check that the requesting user is authorized to view that specific record. Between 16:23:08 and 16:25:28 UTC the session requested id=1 through id=47 in near-sequential order, roughly one record every two to three seconds, every response returning HTTP 200. This exhaustive, ordered, machine-paced sweep from a single source is automated enumeration, not human browsing. 47 distinct employee records were accessed (id=9 and id=23 were re-requested but add no new records).

The distinction that makes this an attack rather than routine use is the combination of an unauthorized account, a single source address, a strictly sequential sweep of the entire id space, and a machine cadence no employee would produce.

Proof of evidence:

```
# Access log : sequential id enumeration from the attacker, all HTTP 200
172.16.50.10 ... "GET /portal/employees.php?id=1 HTTP/1.1" 200 1088
172.16.50.10 ... "GET /portal/employees.php?id=2 HTTP/1.1" 200 1063
... id=3 .. id=47 (47 distinct ids, every response 200)
# Distinct records accessed
$ grep '172.16.50.10' web_access.log | grep -oE 'id=[0-9]+' | sort -u | wc -l
47
```

Recommendation:

- Enforce object-level authorization : verify the authenticated user is allowed to view the requested id before returning a record. Do not rely on the UI to limit reachable ids.
- Rate-limit repeated `employees.php?id=` access from a single session and alert on sequential or high-volume directory access.
- Prefer non-sequential, non-guessable record identifiers (UUIDs) as defence in depth.

References and articles:

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

<https://cwe.mitre.org/data/definitions/639.html>

13. Broken access control on the admin area and bulk PII exfiltration

Severity:

CRITICAL

Finding type:

Authorization flaw (function level) with confirmed data exfiltration

CVSS v3.1 base score:

7.7 base (High) - AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N ; rated Critical for confirmed personal-data exfiltration

CWE:

CWE-862 (Missing Authorization), CWE-284 (Improper Access Control)

MITRE ATT&CK:

T1567 (Exfiltration Over Web Service), T1213 (Data from Information Repositories)

Affected scope:

- /portal/admin/ and /portal/admin/export_users.php (host 192.168.10.26)

Description:

At 16:37:50 UTC the session requested /portal/admin/ and the server returned HTTP 200. For an unauthorized or unauthenticated request the same path returns HTTP 302 (a redirect to the login page), as visible in the access log for scanner traffic against /portal/admin/. The 200 served to a non-admin session is direct proof that the server did not enforce an authorization check on the administrative area. At 16:38:01 UTC the session requested /portal/admin/export_users.php and received HTTP 200 with a 3858-byte response; the size matches the administrative export CSV exactly, and the network capture confirms the response was delivered as text/csv. This is the bulk export and the exfiltration event.

Proof of evidence:

```
# Broken access control : 200 to the attacker vs 302 to unauthorized scanner traffic
172.16.50.10 ... "GET /portal/admin/ HTTP/1.1" 200 2600
172.16.50.20 ... "GET /portal/admin/ HTTP/1.1" 302 523      (unauthorized -> redirect)
# Exfiltration : export endpoint, 3858 bytes = the CSV (text/csv in the pcap)
172.16.50.10 ... "GET /portal/admin/export_users.php HTTP/1.1" 200 3858
```

Impact and data protection:

The exported file holds 47 employee records (name, corporate email, department, job title, phone number, salary band) : personal data under the GDPR. Exposure is not uniform : it includes the top salary band (Chief Financial Officer, Sales Director), the organization's own Data Protection Officer, and the account of the employee compromised by SQL injection in INC-2026-004. This is a confirmed exfiltration of identifiable personal data affecting 47 data subjects. Under GDPR Article 33 the controller must notify the competent supervisory authority (for a Belgian establishment, the Data Protection Authority / Autorite de protection des donnees) without undue delay and, where feasible, within 72 hours of becoming aware;

notification should be treated as required, and Article 34 communication to affected individuals assessed in parallel.

Recommendation:

- **P0 - Enforce function-level (role) authorization server-side** on every /portal/admin/ page and action, including export_users.php. A redirect for unauthenticated users is not authorization.
- Treat this as a reportable breach : proceed with the GDPR Article 33 notification and assess Article 34 communication to affected individuals.
- Log and alert on any non-admin account reaching admin or export endpoints.

References and articles:

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

<https://cwe.mitre.org/data/definitions/862.html>

<https://gdpr-info.eu/art-33-gdpr/>

14. Sensitive debug token disclosed in admin page source

Severity:

LOW

Finding type:

Information disclosure

CVSS v3.1 base score:

3.1 (Low) - AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

CWE:

CWE-615 (Inclusion of Sensitive Information in Source Code Comments), CWE-200

MITRE ATT&CK:

N/A (information disclosure)

Affected scope:

- /portal/admin/ HTML response (host 192.168.10.26)
-

Description:

The HTML returned by /portal/admin/ contains a comment exposing an internal build identifier and a debug token. Sensitive build and debugging information should never be emitted to clients; it aids an attacker and indicates debugging material left in a production response. The token value is omitted from this report as it is a lab artifact; the finding is the disclosure itself.

Proof of evidence:

```
# HTML comment recovered from the admin page response in the network capture (value redacted)
<!-- internal build 2026.06.12 | debug_token=[REDACTED] -->
```

Recommendation:

- Remove debug tokens, internal build markers and developer comments from client-facing responses.
- Add a build step that strips HTML comments and debug artifacts from production output.

References and articles:

<https://cwe.mitre.org/data/definitions/615.html>

Risk Matrix

The 5x5 matrix plots each finding by CVSS-derived Impact (vertical) against Likelihood (horizontal). The upper-right quadrant is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				I3	
High (4)				I2	I1
Medium (3)					
Low (2)			I4		
Very Low (1)					
Critical High Medium Low					

Top-right (most urgent) : I3 (confirmed exfiltration), with I1 (un-removed foothold) and I2 (IDOR) close behind. Remediating the foothold (I1) and enforcing authorization (I2, I3) closes the incident and the class of attack.

MITRE ATT&CK Mapping

Each finding is mapped to MITRE ATT&CK Enterprise techniques (v15).

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
I1	Initial Access / Persistence	T1078	Valid Accounts
I2	Collection	T1119	Automated Collection
I2, I3	Collection	T1213	Data from Information Repositories
I3	Exfiltration	T1567	Exfiltration Over Web Service

Tools and Standards

A. Tools Used During the Engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Network capture analysis	tshark / Wireshark	Inspect the pcap, confirm the export response (text/csv), recover the admin page HTML
SIEM analysis	jq	Query and aggregate the Wazuh alert export
Log analysis	grep / awk / sort / uniq	Filter the access and auth logs, count distinct records, reconcile the account register
Decoding	base64	Decode the disclosed debug token
Evidence retrieval	curl	Download the evidence bundle
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and Frameworks Followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
NIST SP 800-86	2006	Forensic technique integration / evidence handling
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
CVSS	v3.1	Severity scoring
CWE	v4.16	Root-cause classification
OWASP Top 10	2021	A01:2021 Broken Access Control (IDOR + missing authorization)
GDPR	-	Articles 33 and 34 (breach notification)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
IDOR	Insecure Direct Object Reference	Accessing an object via a user-supplied key without an authorization check
BOLA	Broken Object Level Authorization	API equivalent of IDOR (OWASP API Top 10)
BAC	Broken Access Control	Failure to enforce authorization on pages or actions
PII	Personally Identifiable Information	Data that identifies a natural person
GDPR	General Data Protection Regulation	EU data-protection regulation
DPO	Data Protection Officer	Role responsible for data-protection oversight
RBAC	Role-Based Access Control	Authorization model based on roles
CSV	Comma-Separated Values	Text-based tabular data format
IOC	Indicator of Compromise	Artifact pointing to malicious activity
SIEM	Security Information and Event Management	Log aggregation and correlation platform
SOC	Security Operations Center	Team responsible for security monitoring and response
CVSS	Common Vulnerability Scoring System	Numerical severity scoring framework
CWE	Common Weakness Enumeration	Classification of software weaknesses
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
PCAP	Packet Capture	Captured network traffic
UTC / CEST	Coordinated Universal Time / Central European Summer Time	Time references used in this report
HTTP	HyperText Transfer Protocol	Application-layer web protocol
UA	User-Agent	HTTP header identifying the client software

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-007

Classification: Internal - Not for distribution

Analyst

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi